

CNO V: Seguridad Informática



Alumna:

Tristan Rivera Magdalena Yesenia - 174702

Profesor:

Mtro. Servando López Contreras

Fecha: 13/02/2026

Practica: ACTIVIDAD 05

Cartografiando el pentesting: análisis
comparativo de metodologías de seguridad
informática

Grupo: T46B

Horario: 20:00 - 21:00

ACTIVIDAD 05 - Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

Metodología / Marco	Descripción Técnica	Fases de Implementación	Objetivo Principal	Escenarios de Aplicación	Orientación y Enfoque	Autores / Organismo	Material Oficial (URL)	Certificaciones	Versión / Vigencia
MITRE ATT&CK 	Matriz de conocimiento basada en incidentes reales que describe el comportamiento táctico de los adversarios.	No lineal. Estructurada en 14 Tácticas (objetivos) y cientos de Técnicas (métodos).	Modelado de amenazas y detección de brechas en la infraestructura.	Equipos de respuesta a incidentes, SOC y emulación de Red Team.	Híbrida (Ataque/Defensa): Enfocada en entender al atacante para fortalecer la detección.	MITRE Corporation	attack.mitre.org	MITRE ATT&CK Defender (MAD)	v14.1 (Octubre 2023) - Vigente
OWASP WSTG 	El estándar de oro para la seguridad en aplicaciones web, cubriendo todo el ciclo de vida del desarrollo.	11 categorías de prueba (Gestión de Configuración, Identidad, Criptografía, etc.).	Identificación de vulnerabilidades lógicas y técnicas en servicios web.	Auditorías de aplicaciones web y APIs en entornos DevSecOps.	Ataque (Técnico): Pruebas ofensivas específicas para componentes web y servidores.	OWASP Foundation	owasp.org/WSTG	Relacionadas: OSWE, CASE, GWAPT.	v4.2 (Vigente) / v5 (En desarrollo)
NIST SP 800-115 	Guía técnica integral para la planificación y ejecución de pruebas de seguridad informática.	1. Planificación. 2. Ejecución. 3. Post-ejecución (Análisis y Reporte).	Estandarización de procesos de evaluación técnica y cumplimiento.	Sector gubernamental, infraestructuras críticas y cumplimiento federal.	Evaluación (Estratégica): Foco en la validación de controles y gestión de riesgos.	NIST (EE. UU.)	csrc.nist.gov	Alineada con CISA, CISM y certificaciones CISSP.	SP 800-115 (Vigente / Referencia)
OSSTMM 	Metodología científica que utiliza métricas (Ravs) para medir la seguridad operativa real.	1. Visibilidad. 2. Acceso. 3. Confianza. 4. Privacidad. 5. Seguridad Física.	Medición cuantitativa de la seguridad operativa y eficiencia de controles.	Auditorías de red complejas, seguridad inalámbrica y física.	Evaluación (Métrica): Enfoque científico y neutral basado en canales de comunicación.	ISECOM (Pete Herzog)	isecom.org	OPST, OPSRT, OPSE.	v3.0 (Vigente) / v4 (Draft)

PTES 	Estándar de ejecución que garantiza que todas las fases de un pentest se realicen con calidad profesional.	1. Pre-engagement . 2. Intelligence. 3. Threat Modeling. 4. Vuln Analysis. 5. Exploitation. 6. Post-Expl. 7. Reporting.	Definir un estándar de calidad y flujo de trabajo para el pentesting comercial.	Pruebas de penetración de caja negra/blanca a gran escala.	Ataque (Procesal): Define el "cómo" ejecutar el ataque de forma profesional y ética.	Comité de expertos (Nickerson et al.)	pentest-standard.org	Influye en OSCP, CPENT, LPT.	v1.1 (Vigente)
ISSAF 	Marco detallado que conecta la evaluación técnica con la gobernanza y la administración.	1. Planificación. 2. Evaluación. 3. Informe. 4. Limpieza y Destrucción de datos.	Vincular hallazgos técnicos con la estrategia de riesgo empresarial.	Auditorías profundas de sistemas críticos y redes empresariales.	Mixta (Evaluación/Ataque): Enfoque en la profundidad técnica y el orden administrativo.	OISSG	oissg.org	Histórica (Referente en CISA)	v0.2.1 (Vigente como referencia)

Análisis / justificación

1. **Seguridad de Software y Web:** Se debe priorizar **OWASP WSTG**. Es el único marco que profundiza en la lógica de negocio web (ej. bypass de autenticación, inyecciones) con una granularidad que otros marcos generales no ofrecen.
2. **Operaciones de Red y Sistemas:** **PTES** es la elección ideal. Su estructura permite al auditor no saltarse pasos críticos como el "Post-Exploitation", que es donde se mide el impacto real de un compromiso.
3. **Monitoreo y Detección (SOC/Blue Team):** El uso de **MITRE ATT&CK** es obligatorio. Permite comparar las capacidades de detección de la empresa contra las técnicas reales usadas por grupos APT conocidos.
4. **Cumplimiento y Gobernanza:** Para organizaciones que requieren demostrar diligencia debida ante reguladores (especialmente bajo estándares ISO o leyes federales), **NIST SP 800-115** ofrece el rigor documental necesario.
5. **Verificación de Controles Físicos y Lógicos:** Si el objetivo es medir qué tan "expuesta" está una oficina o centro de datos, **OSSTMM** es la única que integra la seguridad física y humana bajo una misma métrica de "visibilidad".

Este análisis comparativo demuestra que no existe una metodología única, sino que la excelencia en el pentesting reside en la combinación estratégica de estos marcos según el objetivo del cliente.